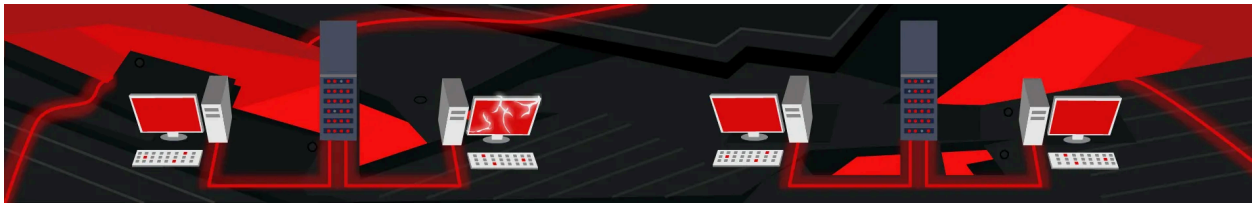


TryHackMe — Room # 1 — Intro to Offensive Security

Introduction

Room Number: 1

Learning Path(s): Introduction to Cyber Security | Pre Security

Difficulty: Easy

Task 1: What is Offensive Security?

In this task, we are introduced to types of security roles i.e. Offensive Security and Defensive Security.

- Which of the following options better represents the process where you simulate a hacker's actions to find vulnerabilities in a system?

  Offensive Security OR ***Defensive Security***

Flag*:* Offensive Security

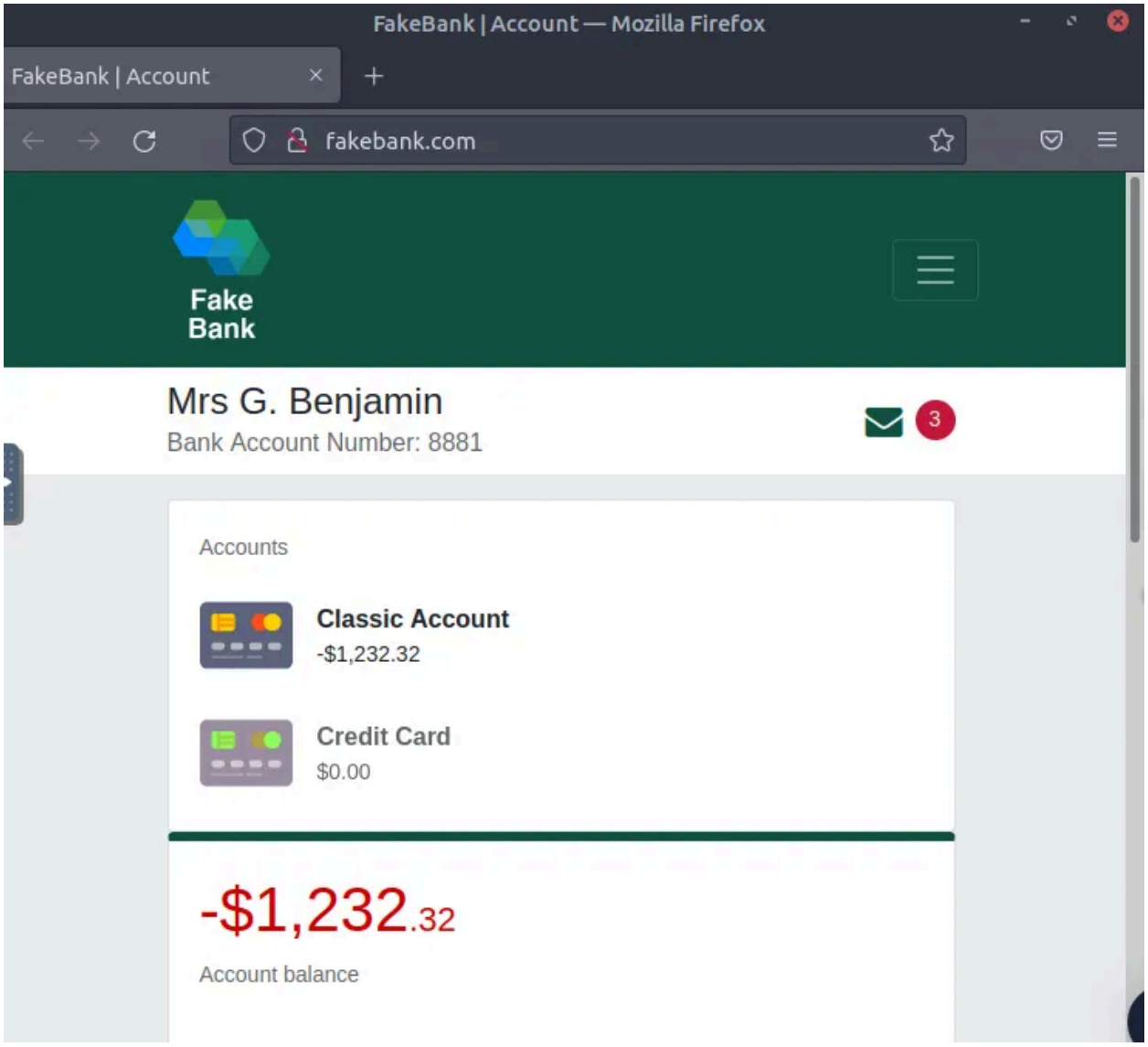
Reason: As stated in the description of this task, "*To beat a hacker, you need to behave like a hacker, finding vulnerabilities and recommending patches before a cybercriminal does, ...*"

Task 2: Hacking your first machine

In this task, we are supposed to hack a fake bank site and perform a transfer between accounts, in the simulated environment. And TryHackMe guides us rightfully for this too.

For this task, we first will be using a utility named as "GoBuster" from the terminal in order to find the hidden website pages.

- Once we'll start the machine, we'll be welcomed by this screen.



- Open terminal from the right side of the machine and type in command: "***gobuster -u http://fakebank.com -w wordlist.txt dir***" in the terminal and hit "Enter".

- "***gobuster***" — Name of Command-Line Application or Utility we are using to brute-force the website and find out its hidden web-pages.
- "***-u***" — Tag being used to set "http://fakebank.com" as target for the utility.

Tag — All the characters or words before which we have "-", are called as tags in the command. Tags are usually used to provide arguments to the utility. Please note, every utility has different tags and every tag has different purposes. You can get a list of these tags for each utility by providing command "[Utility name] -h" in the terminal where "-h" usually stands for "help".

- "***-w***" — Tag being used to set "wordlist.txt" as wordlist for the utility.

Wordlist — Wordlist is literally a list of words. Wordlists are usually used in scenarios where we have multiple possible options and the only

option to get right answers is hit-and-trial method. A few scenarios can be brute-forcing a password, brute-forcing the directory (as in this task), dictionary attack, etc.

***P.S**:* rockyou.txt is a famous wordlist for password cracking. It comes with many other wordlists, built-in in Kali Linux.

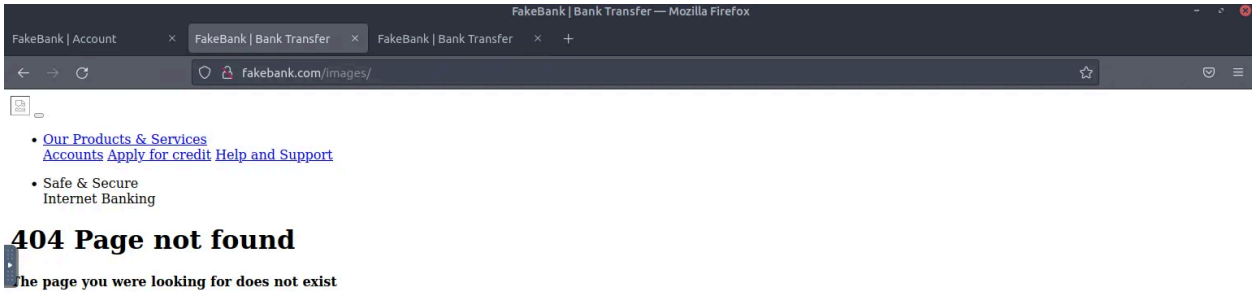
- "***dir***" — stands for "directory". Directory in Linux is same as Folder in Windows.

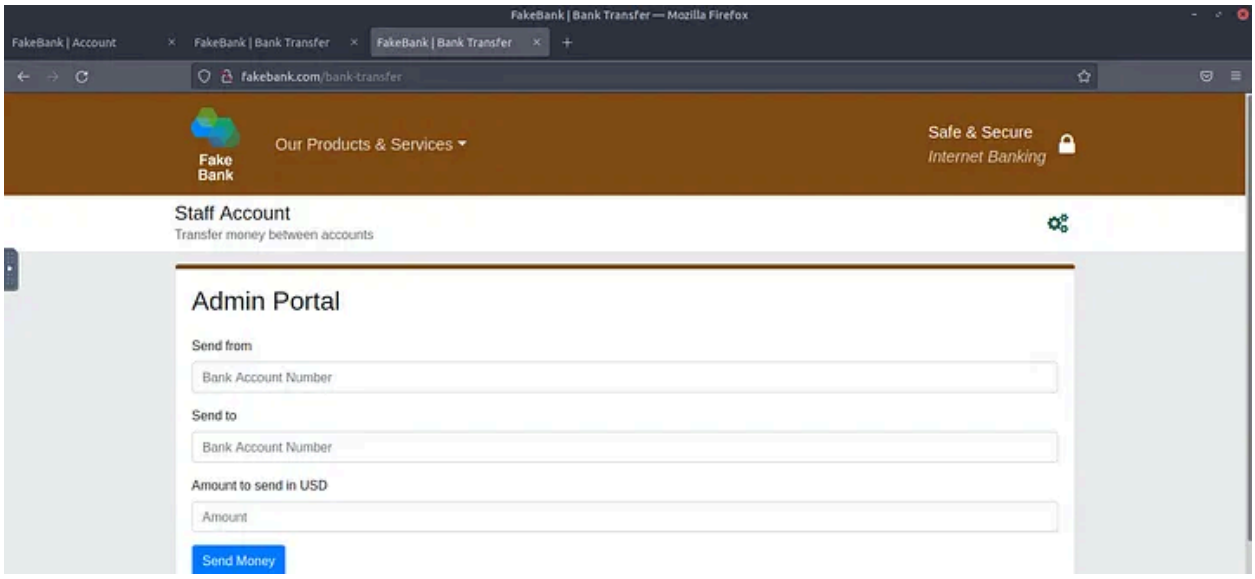
```
ubuntu@tryhackme: ~/Desktop
File  Edit  View  Search  Terminal  Help
ubuntu@tryhackme:~/Desktop$ gobuster -u http://fakebank.com -w wordlist.txt dir

===============================================================
Gobuster v2.0.1                OJ Reeves (@TheColonial)
===============================================================
[+] Mode         : dir
[+] Url/Domain   : http://fakebank.com/
[+] Threads      : 10
[+] Wordlist     : wordlist.txt
[+] Status codes : 200,204,301,302,307,403
[+] Timeout      : 10s
===============================================================
2023/12/31 20:53:24 Starting gobuster
===============================================================
/images (Status: 301)
/bank-transfer (Status: 200)
===============================================================
2023/12/31 20:53:33 Finished
===============================================================
ubuntu@tryhackme:~/Desktop$
```

- Execution of command shows we got two web-pages in the result of the operation we just performed i.e. /images and /bank-transfer. Let's hop over these newly discovered web-pages by entering there URLs in the browser of the machine.

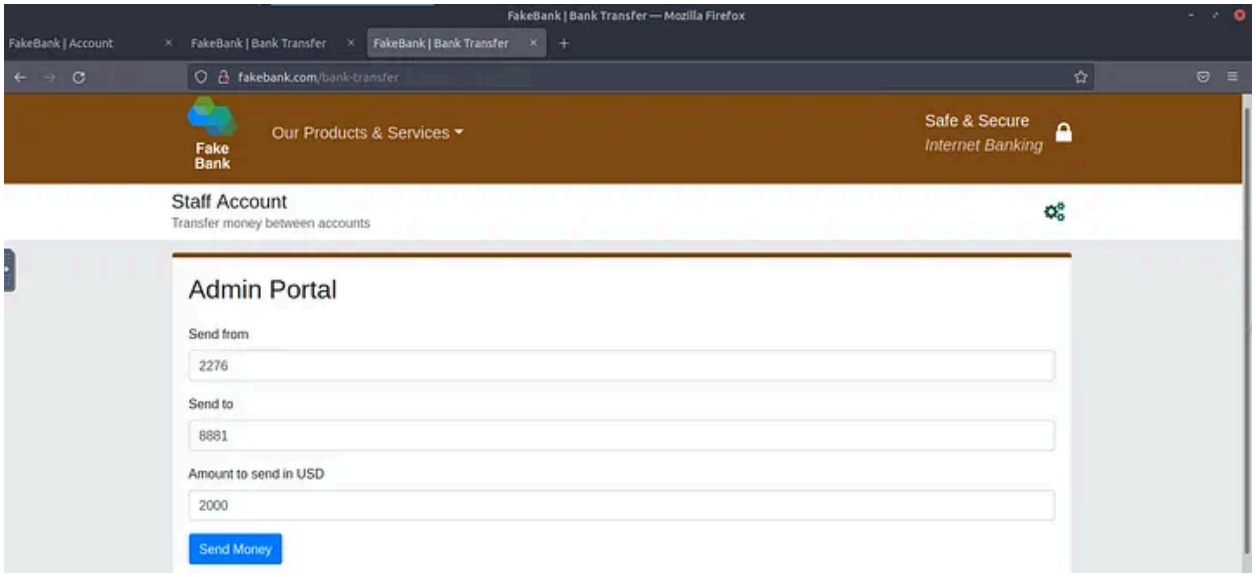
  P.S.: *Web-pages we just discovered will be appended ahead of the main URL i.e. http://fakebank.com as http://fakebank.com/images and http://fakebank.com/bank-transfer.*



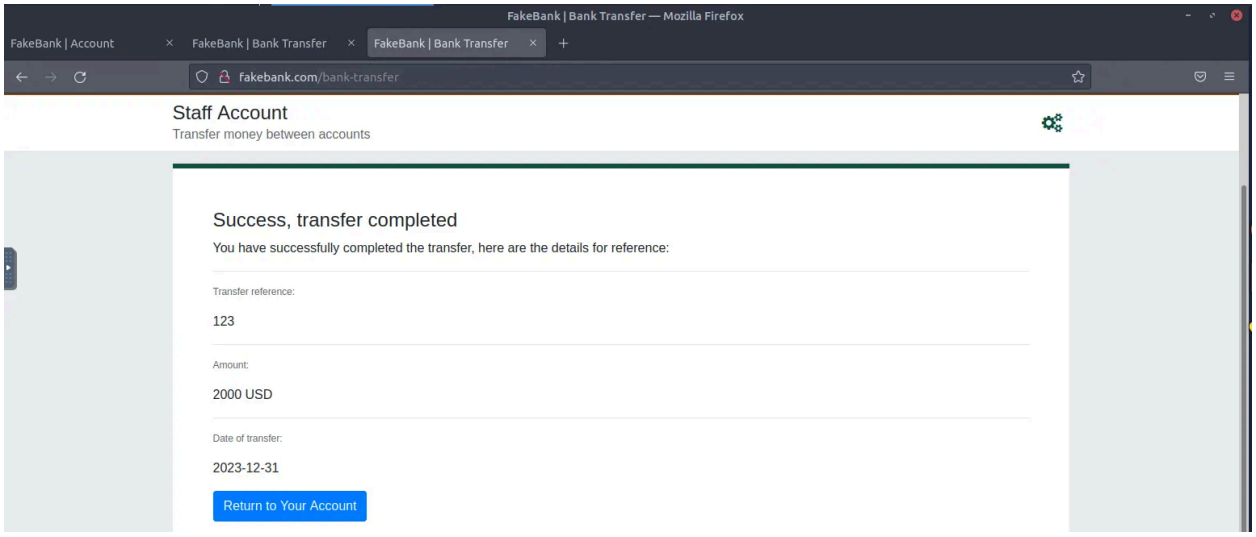


- Whereas http://fakebank.com/bank-transfer hosts the "Admin Portal" for the bank site. This can be used to transfer the amount from one account to another. As we are tasked to transfer $2000 from the bank account 2276, to our account (account number 8881), thus this page would be of our ultimate use.

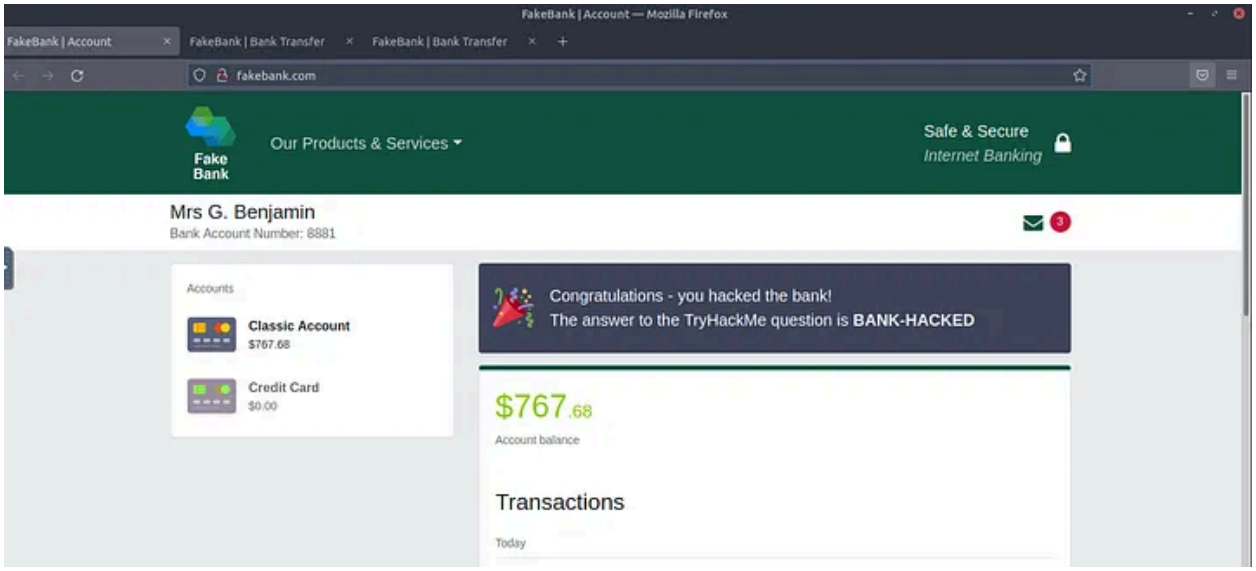
- Fill in the details as required by the task and click over “Send Money”.



- Once you’ll hit “Send Money”, you’ll be shown “Success, transfer complete” message with the particular details of the transaction you just performed.



- Hit “Return to Your Account” to find the answer of the first question in this task i.e. **BANK-HACKED**.



- Above your account balance, you should now see a message indicating the answer to this question. Can you find the answer you need?

Flag: BANK-HACKED

Reason: Process explained above.

- If you were a penetration-tester or security consultant, this is an exercise you'd perform for companies to test for vulnerabilities in their web applications; find hidden pages to investigate for vulnerabilities.

No answer needed, just hit **"Completed"**

- Terminate the machine by clicking the red "Terminate" button at the top of the page.

No answer needed, just hit **“Completed”**

Task 3: Careers in Cyber Security

In this task, we are being introduced to a few offensive security roles i.e. Penetration Tester, Red Teamer and Security Engineer.

- Read the above, and continue with the next room!

No answer needed, just hit **“Completed”**

Conclusion

Today, we hacked into our first website (legally in a safe environment) and experienced an ethical hacker’s job.